

# Semana 24 - Aula 1

Tópico Principal da Aula: Configuração de Servidores Seguros

Subtítulo/Tema Específico: HTTPS, Firewall e Hardening

Código da aula: [SIS]ANO2C2B4S24A1

## Objetivos da Aula:

- Configurar servidores web para garantir a segurança.
- Aplicar o conceito de Hardening para reduzir a superfície de ataque de um servidor.
- Implementar políticas de segurança de rede utilizando Firewall.

## Recursos Adicionais (Sugestão, pode ser adaptado):

- Caderno para anotações;
- Acesso ao laboratório de informática e/ou internet.

## Exposição do Conteúdo:

## Referência do Slide: Slide 06 - Configuração HTTPS e Criptografia em Trânsito

- **Definição:** O protocolo **HTTPS** (Hypertext Transfer Protocol Secure) é a versão segura do HTTP, que utiliza o protocolo **SSL/TLS** (Secure Sockets Layer/Transport Layer Security) para criptografar a comunicação entre o navegador do usuário e o servidor web. A criptografia garante a confidencialidade e a integridade dos dados (como senhas e informações de pagamento) que trafegam na rede.
- **Aprofundamento/Complemento (se necessário):** A base do HTTPS é o Certificado SSL/TLS, emitido por uma Autoridade Certificadora (CA). Este certificado autentica a identidade do servidor e contém a chave pública necessária para iniciar o *handshake* (negociação) de criptografia, estabelecendo uma sessão segura. É crucial utilizar as versões mais recentes do TLS (1.2 ou 1.3) e desabilitar as mais antigas.
- **Exemplo Prático:** Ao acessar um site de e-commerce e ver o ícone de **cadeado** na barra de endereço, seguido por `https://`, o usuário está sob uma conexão segura. Se a criptografia falhar ou se o certificado estiver inválido, o navegador emitirá um aviso de segurança.
  - **Vídeo Sugerido 1:** [O que é HTTPS? SSL/TLS, Criptografia, Handshake e Cifra - Canal HostGator Brasil](#) (Buscar vídeo atualizado sobre HTTPS e TLS)
  - **Vídeo Sugerido 2:** [Como Funciona o TLS/SSL e HTTPS? - Guia Devmedia](#) (Buscar vídeo atualizado sobre o funcionamento técnico)

## Referência do Slide: Slide 08 - Hardening de Servidores e Redução da Superfície de Ataque

- **Definição:** **Hardening** (ou Endurecimento de Sistemas) é o processo de aprimorar a segurança de um sistema através da configuração e desativação de funcionalidades desnecessárias, diminuindo, assim, a **superfície de ataque** potencial. O objetivo principal é tornar o ambiente de TI mais resiliente a ataques cibernéticos.
- **Aprofundamento/Complemento (se necessário):** O Hardening não se limita apenas ao sistema operacional; abrange servidores web, banco de dados e dispositivos de rede. As práticas essenciais incluem: aplicação imediata de patches e atualizações de segurança; remoção de serviços, bibliotecas e contas de usuários que não são estritamente necessários (Princípio do Mínimo Privilégio); e a desabilitação de portas e protocolos inseguros. Recomenda-se seguir padrões como **CIS Benchmarks** e **STIGs**.
- **Exemplo Prático:** Em um servidor Linux rodando um site, o Hardening envolve: desinstalar o servidor FTP (se não for usado), desabilitar a conta de `root` para login remoto (via SSH) e configurar o login apenas via chave pública/privada, e configurar o servidor web (Apache/Nginx) para não exibir a versão do software em *headers* de resposta.
  - **Vídeo Sugerido 1:** [O que é HARDENING? \(e quais as principais referências\) - Canal Cyber Bessa](#)
  - **Vídeo Sugerido 2:** [Hardening de Servidores - Melhores Práticas de Cibersegurança - Canal Hackone](#)

## Referência do Slide: Slide 10 - Implementação de Firewall e Regras Específicas

- **Definição:** **Firewall** é um sistema de segurança de rede que monitora e controla o tráfego de rede de entrada e saída, com base em regras de segurança predeterminadas. Ele atua como uma barreira entre uma rede confiável (interna) e uma rede não confiável (como a internet).
- **Aprofundamento/Complemento (se necessário):** Para um servidor web seguro, o Firewall deve ser configurado com o **Princípio de Mínimo Privilégio**, permitindo apenas o tráfego estritamente necessário. Regras essenciais incluem permitir apenas as portas 80 (HTTP) e 443 (HTTPS) para acesso público e restringir o acesso à porta SSH (22) ou RDP (3389) a faixas de IP específicas (VPNs de administração). O Firewall pode ser baseado em *host* (no próprio servidor, como `ufw` ou `iptables`) ou de rede (um appliance dedicado).
- **Exemplo Prático:** Configurar um firewall no servidor para:
  - **Permitir** conexões de entrada na porta TCP 443 (HTTPS) de qualquer IP.
  - **Permitir** conexões de entrada na porta TCP 22 (SSH) **apenas** do IP do administrador (Ex: 203.0.113.5).
  - **Negar** todo o resto (o padrão é negar/dropar).
  - **Vídeo Sugerido 1:** [O que é Firewall? Como funciona e para que serve? - Guia Devmedia](#) (Buscar vídeo sobre Firewall e segurança de rede)
  - **Vídeo Sugerido 2:** [Configuração básica de Firewall UFW no Linux - Tutorial Linux Tips](#) (Buscar vídeo prático sobre UFW ou IPTables)

---

## Semana 24 - Aula 2

Tópico Principal da Aula: Segurança em APIs

Subtítulo/Tema Específico: Autenticação, Autorização e Prevenção de Ameaças

Código da aula: [SIS]ANO2C2B4S24A2

### Objetivos da Aula:

- Implementar práticas de segurança em.
- Diferenciar autenticação baseada em sessão de autenticação *stateless* (sem estado) usando JWT.
- Conhecer os principais riscos de segurança em APIs (OWASP API Security Top 10).

### Recursos Adicionais (Sugestão, pode ser adaptado):

- Caderno para anotações;
- Acesso ao laboratório de informática e/ou internet.

### Exposição do Conteúdo:

### Referência do Slide: Slide 06 - Autenticação e Autorização com JWT

- **Definição:** **Autenticação** é o processo de verificar a identidade de um usuário ou sistema (Ex: login com usuário e senha). **Autorização** é o processo de determinar se essa identidade verificada tem permissão para realizar uma ação específica (Ex: acessar um recurso de administrador). Nas APIs modernas, o **JSON Web Token (JWT)** é o padrão mais comum para autenticação *stateless*.
- **Aprofundamento/Complemento (se necessário):** O JWT é um token digital que carrega informações (o *payload*, que contém as *claims* ou declarações, como a identidade e as permissões do usuário) e é assinado criptograficamente (*signature*) para garantir sua autenticidade e integridade. Por ser *stateless*, o servidor não precisa armazenar informações de sessão, o que facilita a escalabilidade. No entanto, o token deve ser protegido (geralmente por HTTPS) e a assinatura deve ser forte, pois um token JWT comprometido pode levar a vulnerabilidades como "Autenticação Corrompida de Usuário" (OWASP).
- **Exemplo Prático:** Um usuário faz login (Autenticação) e recebe um JWT. Em seguida, ele tenta excluir um registro (Autorização). O servidor decodifica o JWT, verifica sua assinatura e confirma que o usuário logado tem o *role* (papel) de "Administrador" para executar a exclusão.
  - **Vídeo Sugerido 1:** [Autenticação JWT: como proteger suas APIs de forma moderna - Canal Rocketseat](#) (Buscar vídeo explicativo sobre JWT e APIs)
  - **Vídeo Sugerido 2:** [OWASP API Security Top 10 - Principais Vulnerabilidades em APIs - Tutorial](#) (Buscar vídeo sobre segurança OWASP API)

## Referência do Slide: Slide 08 - Criptografia de Dados em Trânsito e em Repouso

- **Definição:** A **Criptografia** é essencial para proteger a confidencialidade dos dados. A **Criptografia em Trânsito** (ou em Movimento) protege os dados enquanto eles se movem entre sistemas (coberto pelo HTTPS/TLS). A **Criptografia em Repouso** protege os dados armazenados em bancos de dados, discos rígidos ou em serviços de armazenamento em nuvem.
- **Aprofundamento/Complemento (se necessário):** Enquanto a criptografia em trânsito é obrigatória para APIs (utilizando HTTPS), a criptografia em repouso deve ser aplicada a dados sensíveis, como senhas de usuários (armazenadas via **hashing** e *salt*), informações de cartão de crédito e dados pessoais (armazenados via criptografia simétrica ou assimétrica). Proteger o repositório de identidade (onde ficam as chaves e credenciais) é uma prática fundamental.
- **Exemplo Prático:** O servidor de API utiliza HTTPS (criptografia em trânsito) para se comunicar com o cliente. Quando um usuário se cadastra, sua senha é processada por uma função de **hashing** (Ex: Argon2 ou Bcrypt) antes de ser salva no banco de dados, protegendo-a (criptografia em repouso).
  - **Vídeo Sugerido 1:** [Criptografia simétrica vs. assimétrica - Guia Devmedia](#) (Buscar vídeo introdutório sobre criptografia)
  - **Vídeo Sugerido 2:** [Como Armazenar Senhas de Forma Segura - Tutorial Criptografia e Hashing](#) (Buscar vídeo sobre armazenamento seguro de senhas)

## Referência do Slide: Slide 10 - Análise Contínua de Vulnerabilidades

- **Definição:** A **Análise Contínua de Vulnerabilidades** é a prática de testar e avaliar APIs e aplicações de forma recorrente para identificar e remediar falhas de segurança antes que sejam exploradas por atacantes.
- **Aprofundamento/Complemento (se necessário):** Isso inclui a utilização de **scanners de API automatizados** para testes de código fonte e tempo de execução, bem como a realização de **Testes de Penetração (Pen Tests)** periódicos, que simulam ataques reais. As vulnerabilidades mais críticas em APIs são listadas no **OWASP API Security Top 10**, incluindo falhas como Exposição Excessiva de Dados, Falha de Autenticação e Autorização, e Injeção.
- **Exemplo Prático:** Uma equipe de segurança agenda um Pen Test trimestralmente, onde um testador externo tenta explorar vulnerabilidades conhecidas (como Injeção SQL em um endpoint da API) para verificar a eficácia dos controles de segurança implementados.
  - **Vídeo Sugerido 1:** [O que é Teste de Penetração \(Pentest\)? - Visão Geral](#) (Buscar vídeo sobre Pen Testing)
  - **Vídeo Sugerido 2:** [Introdução ao OWASP Top 10 - Conceitos e Riscos](#) (Buscar vídeo sobre OWASP)

---

## Semana 24 - Aula 3

Tópico Principal da Aula: Monitoramento de Segurança

Subtítulo/Tema Específico: SIEM, Análise de Logs e Resposta a Incidentes

Código da aula: [SIS]ANO2C2B4S24A3

### Objetivos da Aula:

- Monitorar a segurança de aplicações e.
- Compreender o papel de uma solução SIEM na gestão centralizada de logs e eventos.
- Desenvolver um protocolo básico para análise e resposta a incidentes de segurança.

### Recursos Adicionais (Sugestão, pode ser adaptado):

- Caderno para anotações;
- Acesso ao laboratório de informática e/ou internet.

### Exposição do Conteúdo:

### Referência do Slide: Slide 06 - Ferramentas de Monitoramento e Alertas

- **Definição:** Ferramentas de Monitoramento de Segurança são utilizadas para estabelecer uma linha de base do que é uma atividade "normal" no sistema e detectar desvios em tempo real. Elas geram Alertas quando padrões anômalos ou ameaças conhecidas são identificadas, permitindo a detecção precoce de atividades maliciosas.
- **Aprofundamento/Complemento (se necessário):** O monitoramento deve ser holístico, abrangendo não apenas logs de segurança, mas também métricas de desempenho do servidor (CPU, memória) e tráfego de rede. Ferramentas como o Nagios (para monitoramento de infraestrutura) e sistemas de gestão de logs (para eventos de segurança) são exemplos de soluções que apoiam a detecção contínua.
- **Exemplo Prático:** Uma ferramenta de monitoramento detecta que o número de requisições falhas de login (HTTP 401) de um determinado IP ultrapassou 100 tentativas em 60 segundos. Isso gera um alerta de "Tentativa de Força Bruta" para o administrador de segurança.
  - **Vídeo Sugerido 1:** [O que é Monitoramento de Rede e Alertas de Segurança? - Guia Técnico](#) (Buscar vídeo sobre monitoramento de rede e alertas)
  - **Vídeo Sugerido 2:** [Introdução ao Nagios \(ou Zabbix\) - Visão Geral](#) (Buscar vídeo sobre ferramenta de monitoramento de infraestrutura)

## Referência do Slide: Slide 08 - Análise Centralizada de Logs (SIEM)

- **Definição:** O **SIEM** (Security Information and Event Management) é uma solução que combina a gestão de informações de segurança (SIM) com a gestão de eventos de segurança (SEM). O SIEM **coleta, agrega, normaliza e analisa** logs e eventos de segurança de diversas fontes (aplicativos, servidores, firewalls, dispositivos de rede) em um painel centralizado.
- **Aprofundamento/Complemento (se necessário):** A principal função do SIEM é a **correlação de eventos**. Ele consegue identificar um padrão de ataque complexo que um log isolado não revelaria, cruzando informações como um login suspeito no servidor A e uma falha de acesso ao banco de dados no servidor B. Além da detecção, o SIEM é fundamental para o gerenciamento de conformidade e a realização de investigações forenses após um incidente.
- **Exemplo Prático:** O log do Firewall mostra que um acesso incomum foi permitido. Simultaneamente, o log da Aplicação registra que um usuário acessou dados sensíveis em horários não usuais. O SIEM correlaciona esses dois eventos e dispara um alerta de "Atividade Anômala/Comprometimento de Conta" com alta severidade.
  - **Vídeo Sugerido 1:** [O que é o SIEM \(gerenciamento de eventos e informações de segurança\)? - Elastic](#) (Buscar vídeo sobre o conceito de SIEM)
  - **Vídeo Sugerido 2:** [Siem Log360 - Monitoramento e resposta a incidentes no SOC - Brasiline Tecnologia](#)

## Referência do Slide: Slide 10 - Protocolo de Análise e Resposta a Incidentes

- **Definição:** Um **Protocolo de Resposta a Incidentes (IRP)** é um conjunto documentado de procedimentos que define como uma organização deve identificar, gerenciar, conter e recuperar-se de um evento de segurança cibernética. Seu objetivo é mitigar os danos e restaurar as operações o mais rápido possível.
- **Aprofundamento/Complemento (se necessário):** As fases típicas de um Protocolo de Resposta a Incidentes (baseadas no NIST) incluem: **Preparação** (documentação, treinamento), **Deteção e Análise** (monitoramento, validação do alerta), **Contenção, Erradicação e Recuperação** (isolação do sistema, correção da vulnerabilidade, restauração do serviço), e **Atividades Pós-Incidente** (lições aprendidas e relatórios). A **Contenção** é a fase mais crítica, focada em limitar o escopo e o impacto do ataque.
- **Exemplo Prático:** Após receber o alerta do SIEM, a equipe de resposta a incidentes segue o protocolo: 1. Isola o servidor comprometido da rede (Contenção). 2. Analisa o vetor do ataque e remove o malware (Erradicação). 3. Restaura o sistema a partir de um backup limpo (Recuperação). 4. Atualiza o Firewall e a política de Hardening (Lições Aprendidas).
  - **Vídeo Sugerido 1:** [O que é IRM \(Incident Response Management\)? - Visão Geral](#) (Buscar vídeo sobre Resposta a Incidentes)
  - **Vídeo Sugerido 2:** [Fases do Processo de Resposta a Incidentes de Segurança - Tutorial](#) (Buscar vídeo sobre as fases do IRP).

